

Avance semana 5

Avance semanal

Divier Jácamo Álvarez

Cetav

Rol: Analista SOC L1

Fecha 09/02/26

Funcionamiento de los sistemas SIEM y su rol en la correlación de eventos

Introducción

Hoy en día, las organizaciones deben lidiar con un aumento de amenazas en el ciberespacio, lo que exige métodos más sofisticados para detectar y responder a estos peligros. Los sistemas de Gestión de Información y Eventos de Seguridad (SIEM) se han vuelto esenciales para manejar la seguridad, ya que permiten recolectar, analizar y relacionar eventos de diversas fuentes. Su mayor ventaja es que pueden convertir grandes cantidades de datos en información útil, lo que ayuda a identificar incidentes de seguridad de manera temprana y cumplir con las normativas.

Concepto y componentes de un sistema SIEM

Un sistema SIEM es una herramienta tecnológica que combina las funciones de Gestión de Información de seguridad y examinar eventos en tiempo real estos sistemas recopilan datos por herramientas de seguridad, como cortafuegos, sistemas que detectan intrusiones y antivirus.

Los elementos principales de un SIEM incluyen el módulo que recoge los datos, el motor que normaliza la información, un sistema que almacena todo de forma centralizada y el motor que analiza y relaciona los eventos la normalización ayuda a uniformizar los eventos de diferentes fuentes, facilitando su análisis después. Además, los SIEM suelen tener paneles de visualización y sistemas que generan alertas, lo que ayuda al equipo de seguridad en su toma de decisiones.

Funcionamiento de los sistemas SIEM

se basa en un ciclo constante que comienza con la recopilación de eventos. Estos datos son enviados al sistema usando agentes o protocolos comunes, como Syslog o API una vez que los eventos llegan, se filtran y normalizan para eliminar la información repetida y ajustarse a un formato estándar.

Después, el SIEM guarda los eventos en repositorios seguros que permiten acceder a ellos en el futuro. Esta capacidad es crucial tanto para el análisis forense como para asegurar que se sigan las normativas de seguridad y auditoría por último, el motor de análisis revisa aplicando reglas establecidas, modelos estadísticos o métodos de análisis avanzado para detectar comportamientos inusuales.

Rol de la correlación de eventos en los SIEM

La correlación de eventos es uno de los elementos más importantes de los sistemas SIEM este proceso implica vincular varios eventos individuales que, por sí solos, pueden no parecer peligrosos pero que, juntos, pueden señalar un posible problema de seguridad a través de reglas de correlación, el SIEM puede identificar patrones complejos, como intentos de acceso no autorizado, movimientos sospechosos dentro de la red o intentos de robar información.

La correlación ayuda a disminuir la cantidad de errores de alerta y a dar prioridad a las notificaciones según su grado de riesgo, mejorando así el trabajo de los analistas de seguridad además, algunos sistemas SIEM modernos utilizan técnicas de aprendizaje automático para aumentar la precisión de la correlación, adaptándose al comportamiento habitual de la infraestructura y reconociendo desviaciones importantes.

Importancia de los SIEM en la gestión de la seguridad

El uso de sistemas SIEM trae beneficios importantes para las organizaciones, como una visión central de la seguridad, una mejor detección de incidentes y la capacidad de responder rápidamente a las amenazas al mismo tiempo, los SIEM ayudan a cumplir con normas y regulaciones como ISO/IEC 27001, PCI DSS y GDPR, al ofrecer pruebas y reportes detallados sobre eventos de seguridad.

Sin embargo, la efectividad de un SIEM depende de una configuración adecuada, del diseño correcto de las reglas de correlación y del entrenamiento del personal que lo maneja si no se tienen en cuenta estos factores, el sistema puede producir un gran número de alertas inútiles o ignorar incidentes importantes.

Conclusión

Los sistemas SIEM son fundamentales para proteger los sistemas de información, ya que permiten la recolección, análisis y correlación de eventos de seguridad de forma centralizada. Su habilidad para correlacionar eventos de diferentes fuentes los convierte en herramientas esenciales para detectar a tiempo amenazas complejas. En un entorno digital que se vuelve más dinámico y peligroso, implementar correctamente un SIEM es un elemento clave en cualquier programa completo de ciberseguridad.

Diagrama de Flujo de monitoreo de SOC

Explicación del flujo

Dispositivos y sistemas para hospitales psiquiátricos.

Estos incluyen sistemas de registros médicos electrónicos, servidores de bases de datos de pacientes, estaciones de trabajo del personal médico, cámaras de seguridad, firewalls y sistemas de control de acceso físico y lógico.

Generación de eventos

Se produce un incidente, por ejemplo, un intento de obtener acceso no autorizado a un sistema de registro de pacientes psiquiátricos. Colección de registros

Los registros generados por los sistemas se envían al SIEM mediante agentes o protocolos como Syslog.

Normalización y filtrado en SIEM

SIEM estandariza eventos para facilitar el análisis y eliminar información redundante o irrelevante. Almacenamiento centralizado

Los eventos se almacenan en un repositorio seguro que permite auditorías y análisis forenses posteriores, lo cual es fundamental debido a la sensibilidad de los datos de salud mental.

Correlación de eventos

SIEM correlaciona múltiples eventos, como accesos fallidos repetidos fuera del horario comercial y desde una ubicación inusual, para identificar patrones de riesgo.

Evaluación del evento

Se determina si el comportamiento es consistente con una actividad normal o sospechosa.

Clasificación del nivel de riesgo

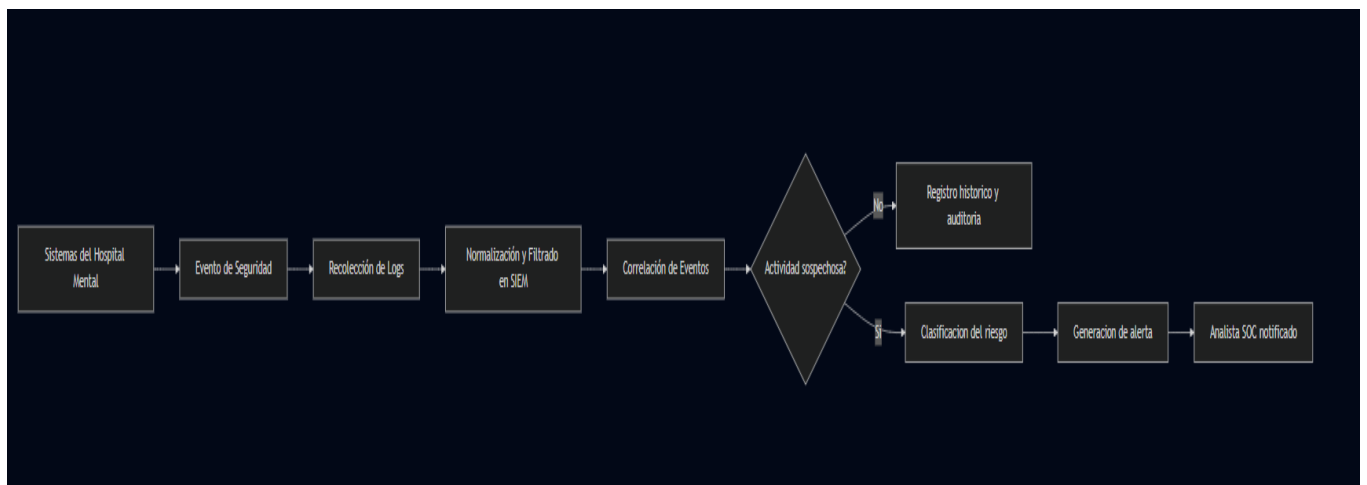
Si el evento es sospechoso, se clasifica según su impacto y criticidad, teniendo en cuenta la

confidencialidad de la información médica. Generación de alarma

El SIEM crea una alerta detallada con información relevante sobre el evento detectado.

Declaración del analista de SOC

Un analista recibe una alerta para comenzar el proceso de análisis, contención y respuesta al incidente.



Validación manual de incidentes por analista SOC

Introducción

Aunque los sistemas SIEM automatizan la recopilación, el análisis y la correlación de eventos de seguridad, la intervención de los analistas de SOC sigue siendo fundamental para garantizar una detección precisa de eventos en entornos sensibles, como un hospital psiquiátrico donde se manejan datos clínicos altamente confidenciales, la validación manual es clave para reducir los falsos positivos y evaluar adecuadamente el impacto de los eventos detectados.

Puntos críticos de validación manual.

Uno de los puntos más importantes en los que debe intervenir un analista es la correlación posterior al evento, donde SIEM identifica patrones potencialmente maliciosos. El analista valida el contexto del evento, teniendo en cuenta factores como horarios atípicos, roles del personal médico y acceso de emergencia que son comunes en entornos de atención médica.

Otro punto importante es la clasificación del nivel de riesgo. Mientras el SIEM asigna un nivel de gravedad inicial, el analista evalúa manualmente el impacto real en la confidencialidad, integridad y disponibilidad de la información psiquiátrica, ajusta la prioridad de alerta según el sistema afectado y el tipo de datos involucrados.

Además, durante la revisión de las alertas generadas, el analista confirma la validez técnica del evento, verifica configuraciones, eventos relacionados y recurrencia. Esta validación evita la escalada innecesaria de alertas inapropiadas y optimiza la respuesta del SOC. Finalmente, antes de pasar a un incidente de seguridad, el analista decide manualmente si activa protocolos de respuesta, notifica el cumplimiento legal o regulatorio, lo cual es especialmente importante en las organizaciones de atención médica.

Documentación técnica del proceso de monitorización de seguridad SOC.

Introducción

El monitoreo de seguridad es una función clave ya que permite la detección, análisis y respuesta oportuna a eventos que puedan comprometer los sistemas de información en un hospital psiquiátrico, este proceso adquiere mayor relevancia debido a la sensibilidad de los datos clínicos y psiquiátricos ingresados. El monitoreo técnico se basa principalmente en sistemas SIEM que automatizan la recopilación y el análisis de eventos, aunque se requiere monitoreo y validación humanos para garantizar su efectividad.

Una colección de eventos

El proceso técnico comienza con la recopilación de eventos de seguridad generados por varios sistemas hospitalarios, como registros médicos electrónicos, servidores de bases de datos, estaciones de trabajo del personal médico, dispositivos de red y sistemas de control de acceso estos eventos se reenvían al SIEM mediante agentes o protocolos estándar como Syslog y API, asegurando la integridad y disponibilidad de los registros

Normalización y almacenamiento.

Después de la agregación, los eventos se normalizan, es decir, se transforman en un formato común que facilita su análisis este proceso elimina inconsistencias y reduce la complejidad que surge de múltiples fuentes luego, los eventos normalizados se almacenan en un repositorio centralizado y seguro que proporciona consulta histórica, análisis forense y cumplimiento de los requisitos reglamentarios de la industria de la salud.

Análisis y coherencia de eventos

SIEM realiza análisis y correlación de eventos utilizando reglas y patrones de comportamiento predefinidos. Esta fase identifica patrones que pueden indicar actividad maliciosa, como acceso no autorizado repetido a registros clínicos o intentos de autenticación fuera del horario comercial normal. La correlación permite contextualizar eventos aislados y reducir el número de alertas irrelevantes

Generación y reconocimiento de alertas

Cuando se detecta actividad sospechosa, el sistema genera una alerta que se envía al analista de SOC en este punto, el analista realiza una validación técnica manual que analiza el contexto del evento, la criticidad del sistema afectado y la sensibilidad de la información involucrada esta confirmación es importante para confirmar la legitimidad de la alerta antes de una escalada.

Escalamiento y registro

Si la alerta se confirma como un potencial incidente, el analista procede con el escalamiento, activa los protocolos de respuesta adecuados y notifica a las áreas responsables todos los eventos y decisiones tomadas durante el seguimiento quedan documentados, permitiendo mantener la trazabilidad, mejorar los procesos de seguridad y cumplir con la normativa de protección de datos sanitarios.

Conclusión

El proceso de monitoreo técnico en un SOC consta de eventos hasta la confirmación y escalamiento de alertas este proceso es crucial para proteger la confidencialidad y la integridad de la información la combinación de la automatización SIEM y la intervención de los analistas SOC garantiza una gestión de la seguridad más precisa y eficiente.

Referencias

- Scarfone, K., & Souppaya, M. (2016). *Guide to computer security log management* (NIST Special Publication 800-92). National Institute of Standards and Technology.
- Chuvakin, A., Schmidt, K., & Phillips, C. (2013). *Logging and log management: The authoritative guide to understanding the concepts surrounding logging and log management*. Syngress.
- IBM Security. (2021). *QRadar SIEM: Architecture and deployment guide*. IBM Corporation.
- ISO/IEC. (2022). *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. International Organization for Standardization.
- ENISA. (2020). *Threat landscape report*. European Union Agency for Cybersecurity.